

Clinic Cloud Mission 2

Security Assessment Compendium

Reused final security-assurance reports located in the prior project conversations

This compendium preserves the existing Mission 2 assessment work instead of recreating it. It is a supporting security-assurance record for the clinic-cloud-iac portfolio closeout; it does not change the final delivery status of Waves 0 through 6 and does not claim production certification.

Reuse boundary

The included domain reports are the final PDFs recovered from the project's ChatGPT conversation history. The A2 through A5 reports were already free of account IDs, ARNs, service resource IDs, credentials, and email addresses under the package scan. A6 and A7 contained infrastructure identifiers and were therefore redacted in the portfolio copy while preserving findings, conclusions, dates, control logic, and evidence references.

A standalone A1 Identity and Access final PDF was not present in the retrieved set. The chat record states that its final condition was reconstructed in the later A8 assessment rather than represented by a fabricated A1 document.

The conversation record also confirms that a 19-page A8 Mission 2 Final Readiness Assessment was generated with the verdict PASS WITH CONTROLLED CONDITIONS / MISSION 2 READY TO CLOSE. That generated file was not available as a retrievable local attachment, so this compendium does not silently substitute or reconstruct it.

Recovered assessment register

Domain	Assessment	Final position	Portfolio treatment
A2.7-E08	Logging failure and tampering detection	PASS	Reused
A3.8	Detection and security monitoring	PASS	Reused
A4.8	Network security	PASS / CLOSED	Reused
A5.8	Data protection and encryption	PASS	Reused
A6.8	Backup and recovery security	PASS / CLOSED	Sanitized reuse
A7.8	Configuration and compliance	PASS + approved exceptions / CLOSED	Sanitized reuse

Relationship to the W0-W6 closeout

Mission 2 records the cross-cutting security and governance baseline: identity, auditability, detection, network controls, encryption, recoverability, configuration, and compliance. The W0-W6 closeout records a later delivery sequence whose outcomes include implementation, partial deployment, validated design without deployment, and external termination. The security assessments therefore support the portfolio narrative but must not be used to imply that the Pharmacy, Clinic/EMR, Appointment API, or hybrid VPN workstreams reached production go-live.

Public-use guidance

Use this compendium as a technical appendix or interview evidence set. Retain the original unredacted A6 and A7 source files privately. For public portfolio publication, use only this sanitized compendium and the sanitized W0-W6 closeout package.

Included source reports follow in their original order.

M2-A2.7-E08

Final Logging Failure & Tampering Detection Assessment

Mission 2 - Security & Monitoring Validation | A2 - Logging & Audit Validation

Overall Status	PASS
----------------	------

1. Assessment Objective

A2.7 evaluated whether the clinic AWS environment can detect, alert on, and support investigation of events that could weaken or interrupt centralized audit logging. The assessment covered two major failure classes: **intentional or attempted tampering** with CloudTrail and Log Archive controls, and **operational logging delivery failure** affecting S3, CloudWatch Logs, or CloudTrail digest delivery.

The validation approach intentionally avoided destructive changes to the real Control Tower organization trail and protected Log Archive. Where a live change would create unnecessary risk, synthetic event-pattern tests, a nonexistent trail target, or synthetic metric datapoints were used to validate the detection path safely.

2. Evidence Summary

Evidence	Validation	Result
E01	Organization trail health baseline: active logging, recent S3/CloudWatch/digest delivery, no reported delivery errors.	PASS
E02	Existing monitoring inventory identified no dedicated tamper metric filters or security alarms.	GAP FOUND
E03	CloudTrail and Log Archive tamper patterns validated with positive and negative synthetic tests.	PASS
E04	Central CloudWatch metric filters and alarms implemented for CloudTrail-control and Log Archive-control tampering.	PASS
E05	Safe tamper attempt generated, reconstructed, emitted a metric datapoint, triggered an alarm, and returned to OK. Log Archive alarm path also validated synthetically.	GOLD
E06	Live delivery-health visibility validated; synthetic S3 delivery failure and stopped-logging conditions correctly classified as unhealthy.	PASS
E07	SNS alert routing, confirmed human subscription, delivery test, and cross-account analyst triage from the central archive validated.	GOLD

3. Tamper Detection Outcome

The initial E02 review confirmed a genuine monitoring gap: the organization trail was healthy, but no dedicated CloudWatch Logs metric filters or CloudWatch alarms were present for security-relevant changes to CloudTrail or the centralized S3 Log Archive. This was recorded as **F-A2.7-01 - Proactive Logging-Tamper Detection Not Configured**.

The gap was remediated by implementing two centrally managed detection paths in the **Clinic/SecurityLogging** metric namespace: **Clinic-CloudTrail-Control-Tamper** for CloudTrail control changes and **Clinic-LogArchive-Control-Tamper** for protected S3 Log Archive control changes. Each metric filter is associated with a dedicated CloudWatch alarm using a one-minute evaluation period and threshold of one event.

Detection Domain	Examples Covered	Status
CloudTrail control	StopLogging, DeleteTrail, UpdateTrail, PutEventSelectors, PutInsightSelectors	Automated
Log Archive control	Bucket policy, versioning, lifecycle, encryption, and public-access-control changes	Automated
S3 object-level deletion	DeleteObject / DeleteObjectVersion require targeted S3 data-event coverage	Residual

4. Safe End-to-End Tamper Validation

A controlled **StopLogging** request was issued against a deliberately nonexistent trail. The operation returned **TrailNotFoundException**, leaving the real **aws-controltower-BaselineCloudTrail** organization trail untouched. CloudTrail recorded the attempted control-plane operation, the metric filter emitted a **CloudTrailControlTamper = 1** datapoint, and the CloudWatch alarm transitioned from **OK to ALARM** before returning to **OK**.

The Log Archive alarm stage was validated separately with a synthetic **LogArchiveControlTamper = 1** metric datapoint. This deliberately avoided modifying the protected Control Tower log bucket while still confirming that the alarm path transitions correctly.

Result: the CloudTrail tamper detection chain was validated end to end using a real management API attempt, while the Log Archive detection path was validated through synthetic filter and alarm testing to preserve the integrity of the evidence repository.

5. Logging Delivery-Failure Visibility

The organization trail reported **IsLogging = True** and no current errors for S3 delivery, CloudWatch Logs delivery, or digest delivery. Recent delivery timestamps were present for all three destinations, establishing a healthy live baseline.

The health-evaluation logic correctly classified the live environment as healthy. Synthetic test inputs containing an S3 delivery failure and a stopped-logging state were both classified as unhealthy, demonstrating that these failure conditions can be recognized without intentionally breaking the production logging path.

Health Signal	Current State	Detection Result
IsLogging	True	Healthy
S3 delivery error	None	Healthy
CloudWatch Logs delivery error	None	Healthy
Digest delivery error	None	Healthy
Synthetic S3 delivery failure	Injected in test logic	Unhealthy detected
Synthetic stopped logging	IsLogging = false	Unhealthy detected

6. Alert Routing and Analyst Triage

A dedicated SNS topic, **Clinic-Security-Logging-Alerts**, was created as the central notification channel. Both tamper alarms have alarm actions enabled and route to this topic. A confirmed email subscription was established and a controlled SNS delivery test was successfully received by the configured human notification endpoint.

Cross-account analyst triage was also validated. The dedicated **Clinic-Log-Audit-Analyst** role reconstructed the Management-account synthetic StopLogging event from the centrally aggregated organization-trail S3 archive. The analyst identified the event time, federated actor, target trail, Region, error result, and source information without requiring Management-account administrative access.

Stage	Validation	Result
Detection	CloudTrail / Log Archive metric filters	PASS
Alarm	CloudWatch alarms transitioned as designed	PASS
Routing	Alarm actions route to Clinic-Security-Logging-Alerts	PASS
Delivery	Confirmed human subscription received test message	PASS
Triage	Audit analyst reconstructed cross-account tamper event from central archive	PASS

7. Findings and Residual Risk

F-A2.7-01 - Proactive Logging-Tamper Detection Not Configured

Initial status: OPEN

Final status: **REMEDIATED**

Remediation: central metric filters, CloudWatch alarms, SNS routing, human notification delivery, and analyst triage were implemented and validated.

Residual Observation R-A2.7-01 - Delivery-health notification is not yet automated. The environment exposes S3, CloudWatch Logs, and digest-delivery health and the evaluation logic correctly detects unhealthy conditions, but no scheduled automated process currently publishes delivery-health failures to the security alert topic. This is a monitoring-maturity improvement rather than a failure of the current trail.

Residual Observation R-A2.7-02 - Object-level S3 log deletion detection depends on targeted S3 data-event coverage. Management-plane changes to the Log Archive are proactively monitored, but DeleteObject and DeleteObjectVersion require the targeted S3 data-event design already tracked under the A2.3 post-migration requirement.

8. Final Conclusion

A2.7 - Logging Failure & Tampering Detection: PASS.

The clinic AWS environment now provides proactive detection for security-relevant CloudTrail and centralized Log Archive control changes. The original monitoring gap identified during E02 was remediated through CloudWatch

Logs metric filters, custom security metrics, CloudWatch alarms, SNS notification routing, and a confirmed human notification endpoint.

A safe end-to-end tamper validation demonstrated that a StopLogging-style event can be recorded, converted into a security metric, transition the CloudWatch alarm into ALARM, and subsequently return to OK without modifying the real Control Tower organization trail. The Log Archive alarm path was validated synthetically to avoid altering protected audit evidence.

Logging delivery health is visible through CloudTrail status information, and test logic correctly distinguishes healthy operation from delivery-error or stopped-logging conditions. Cross-account triage was demonstrated by the dedicated audit analyst using the centralized organization-trail archive rather than privileged Management-account access.

The resulting control chain demonstrates effective **detection -> alarm -> notification -> analyst investigation** for logging-control tampering, with documented residual improvements for automated delivery-health notification and targeted S3 object-level data-event monitoring.

Control	Status
A2.7-E01 Organization Trail Health	PASS
A2.7-E02 Existing Detection Inventory	GAP IDENTIFIED
A2.7-E03 Tamper Detection Pattern Validation	PASS
A2.7-E04 Metric Filters and Alarms	PASS
A2.7-E05 Safe Tamper Detection Validation	GOLD
A2.7-E06 Delivery-Failure Visibility	PASS
A2.7-E07 Alert Routing and Analyst Triage	GOLD
A2.7-E08 Final Assessment	COMPLETE
F-A2.7-01 Proactive Tamper Detection Gap	REMEDIED

Final A2.7 Status: PASS - Logging tampering is proactively detected and routed for analyst investigation; delivery-health visibility is validated with residual automation improvements documented.

A3.8 - Detection & Security Monitoring Final Assessment

Mission 2 - Security & Monitoring Validation

Final verdict: A3 PASS

PASS

All A3 control areas (A3.1 through A3.7) were validated and closed successfully. The final control state includes centralized Security Hub governance, organization-wide GuardDuty and Inspector coverage, tested alert routing, and a resolved end-to-end sample security event.

Assessment item	Verified result
Region	ap-southeast-2 (Sydney)
Security Hub CSPM	Central configuration active; organization-wide baseline policy applied; AWS Foundational Security Best Practices v1.0.0 enabled.
GuardDuty	Core GuardDuty enabled for all organization accounts; S3 Protection and EC2 Malware Protection enabled cross-account.
Amazon Inspector	Delegated administrator established; all existing accounts activated; automatic activation enabled for future member accounts.
Inspector resource coverage	EC2: 0/0; ECR: 0/0; Lambda: 5/5 covered; Lambda code scanning: 5/5 covered.
Alert path	Security Hub -> EventBridge -> SNS -> email subscriber successfully tested with a GuardDuty HIGH sample finding.
Incident lifecycle	Controlled HIGH sample finding reviewed, classified as a test event, and moved to RESOLVED.

Assessment conclusion

A3 demonstrates that the clinic landing zone can detect security-relevant activity, centralize findings, route prioritized alerts to a human notification channel, and complete a documented finding lifecycle. The control set was validated operationally rather than accepted on configuration state alone.

1. Control-by-control result

Control	Area	Result	Validation summary
A3.1	Detection architecture baseline	PASS	Security Hub, GuardDuty and Inspector baseline recorded; organization administration and coverage gaps identified for remediation.
A3.2	Security Hub CSPM	PASS	Converted from local to central configuration; ap-southeast-2 retained as home Region; policy applied across the organization; management-account AWS Config prerequisite remediated.
A3.3	GuardDuty threat detection	PASS	Core GuardDuty enabled for all accounts and future members; S3 Protection and GuardDuty-initiated EC2 malware scanning enabled organization-wide.
A3.4	Amazon Inspector	PASS	Inspector delegated administration corrected in ap-southeast-2; all accounts activated; future member auto-activation enabled; Lambda and Lambda code coverage verified at 5/5.
A3.5	Finding routing & alerting	PASS	EventBridge rule routes ACTIVE HIGH/CRITICAL Security Hub findings with NEW/NOTIFIED workflow status to the clinic-security-alerts SNS topic.
A3.6	End-to-end detection test	PASS	GuardDuty HIGH sample finding appeared in Security Hub and generated the expected SNS email notification.
A3.7	Triage & finding lifecycle	PASS	Controlled sample event reviewed, identified as a simulated security event, and resolved without unnecessary containment action.

2. Final detection architecture

```

AWS Organization
|
+-- GuardDuty
|   +-- Core detection: all accounts
|   +-- S3 Protection: all accounts
|   +-- EC2 Malware Protection: all accounts
|
+-- Amazon Inspector
|   +-- All current accounts activated
|   +-- Future accounts auto-activated
|   +-- Lambda: 5/5 covered
|   +-- Lambda code scanning: 5/5 covered
|
+-- Security Hub CSPM
    +-- Central configuration / FSBP baseline
    +-- HIGH / CRITICAL finding filter
        |
        +-- EventBridge
            +-- SNS: clinic-security-alerts
                +-- Email subscriber
  
```

3. Findings and remediation register

ID	Finding	Root cause / remediation	Status
A3-F07	Inspector covered only the Security account.	Regional Inspector delegated administration was not correctly established in ap-southeast-2. Delegated administration was corrected; all current accounts were activated; future member auto-activation was enabled.	CLOSED
A3-F08	Security Hub used Local configuration.	Converted Security Hub CSPM to centralized configuration and applied an organization-wide FSBP baseline policy.	CLOSED
A3-F09	Security Hub policy failed on management account; root also failed.	AWS Config had not been started in the Organizations management account. AWS Config recording was enabled and the central policy subsequently passed for the management account and organization root.	CLOSED
A3-F10	GuardDuty was not enabled across organization accounts.	Organization coverage and auto-enable were configured so all current accounts and future members are protected by core GuardDuty.	CLOSED
A3-F11	EC2 Malware Protection failed organization-wide enablement.	The delegated administrator lacked the required AWS Organizations permission. The required organization-level permission was granted from the management account, then EC2 Malware Protection was enabled for all accounts.	CLOSED

4. Protection-plan applicability decisions

Capability	Decision	Rationale
GuardDuty S3 Protection	Enabled - all accounts	Relevant to organization-wide S3 activity and centrally managed security data.
GuardDuty EC2 Malware Protection	Enabled - all accounts	Baseline capability retained for present or future EC2 workloads; organization permission issue remediated.
GuardDuty Runtime Monitoring	Deferred / N/A	No applicable EC2, ECS or EKS runtime workload was present for the planned Non-Prod pilot. No unnecessary compute was created solely for testing.
GuardDuty RDS Protection	N/A	No RDS/Aurora workload confirmed in the current pilot.
GuardDuty Lambda Protection	N/A for current GuardDuty plan	No Lambda workload was confirmed in the Non-Prod workload inventory; Inspector later verified five Lambda functions elsewhere in the organization and covered all of them.
EKS / ECS protection	N/A	No EKS or ECS workload exists in the current pilot.

5. End-to-end validation evidence

The final functional test used a GuardDuty HIGH-severity sample finding. The test did not require creation of an intentionally vulnerable or compromised production resource.

Stage	Observed result	Assessment
1. GuardDuty	HIGH sample finding generated successfully.	PASS
2. Security Hub CSPM	Sample finding appeared in centralized Security Hub findings.	PASS
3. EventBridge	Rule clinic-securityhub-high-critical-alerts matched the intended HIGH/CRITICAL, ACTIVE, NEW/NOTIFIED pattern.	PASS
4. Amazon SNS	Matched finding was published to clinic-security-alerts.	PASS
5. Human notification	SNS email was received by the confirmed subscriber.	PASS
6. Finding lifecycle	The HIGH test finding was reviewed and moved to RESOLVED.	PASS

6. Residual conditions and accepted limitations

Condition	Treatment
No EC2 resources in the verified Non-Prod account	Accepted. EC2 Runtime Monitoring remains deferred because no applicable runtime workload exists.
No ECR resources	Accepted. Inspector ECR scanning remains enabled as a preventive baseline for future container images.
No current Inspector findings	Accepted. All applicable resources were covered; absence of findings is a clean-state result, not a control failure.
Security Hub linked Regions	No linked Regions configured. The assessment scope remains ap-southeast-2 and automatic linking of future Regions is disabled.

A3.8 final decision

PASS

A3 - Detection & Security Monitoring is assessed as PASS.

All identified A3 governance and coverage findings were remediated and revalidated. The HIGH-severity test confirmed operational routing from GuardDuty to Security Hub, EventBridge, SNS, and the receiving analyst channel, followed by deliberate resolution of the sample finding.

Mission 2 may proceed to A4 - Network Security Validation.

Recommended evidence attachments (outside this single assessment PDF)

For the project evidence pack, retain screenshots or exports showing: Security Hub central policy success; GuardDuty organization coverage and protection plans; Inspector organization activation and 5/5 Lambda coverage; EventBridge rule configuration; SNS subscription confirmation; HIGH sample finding in Security Hub; notification email; and the finding workflow state after resolution.

Mission 2 - A4.8

Final Network Security Assessment

Healthcare Cloud Security Engineering Project - Secure AWS Migration for a Clinic Management System

FINAL RESULT: PASS	
Assessment domain	A4 - Network Security
Environment	Clinic Non-Production VPC, ap-east-1
Assessment status	PASS - A4 CLOSED
Open High/Medium findings	0
Residual risk	Low
Next mission section	A5 - Data Protection / Encryption
Assessment date	7 September 2026

Executive conclusion. The clinic Non-Production network now demonstrates intentional private-resource placement, controlled Internet routing, purpose-specific security-group use, validated flow-log delivery, and explicit path testing. Temporary pilot infrastructure and permissive default-security-group rules discovered during review were removed. No unresolved High or Medium network-security findings remain.

The assessment also verified an important functional-security balance: Internet-originated paths to FSx SMB and Active Directory LDAP are blocked, while the required FSx-to-AD LDAP path remains reachable.

1. Scope and Control Outcome

Control	Assessment focus	Result
A4.1	Network architecture and current-state baseline	PASS
A4.2	VPC and subnet segmentation	PASS
A4.3	Route tables, Internet exposure and egress	PASS
A4.4	Security groups and network ACLs	PASS
A4.5	VPC endpoints and private service access	PASS
A4.6	VPC Flow Logs and network visibility	PASS
A4.7	Reachability and exposure validation	PASS
A4.8	Final network security assessment	PASS

2. Final Network Architecture Assessment

Area	Validated state
VPC	Non-default clinic VPC using 10.0.0.0/16 in ap-east-1.
Private tier	FSx for Windows and AWS Managed Microsoft AD remain on private subnets with no default Internet route.
Public tier	Two permanent public subnets remain available for deliberate future ingress/network components; they are currently empty and do not auto-assign public IPv4 addresses.
Internet routing	Only the explicit public route table has 0.0.0.0/0 to the Internet Gateway. The VPC main route table is local-only.
NAT	No NAT Gateway is deployed. Private subnets therefore have no generic Internet egress.
Public exposure	No Elastic IPs, public EC2 addresses, Internet-facing load balancers, or active ENIs were found in the public tier.

3. Findings and Remediation Closure

ID	Severity	Finding	Final state
A4-F01	High	Regional security-monitoring gap in the actual workload region (ap-east-1).	CLOSED - Security Hub, GuardDuty and Inspector enabled/validated; cross-region HIGH-finding alert path confirmed.
A4-F02	Med/High	VPC Flow Logs were not enabled for the clinic VPC.	CLOSED - VPC-level ALL traffic logging enabled with 60-second aggregation and successful S3 delivery.
A4-F03	Medium	Dedicated secure log-storage/KMS dependency required for Flow Logs.	CLOSED - Dedicated Log Archive S3 destination and customer-managed KMS encryption established.
A4-F04	Low/Med	Residual temporary FSx pilot public-client subnets and route table created latent Internet exposure.	CLOSED - Dependency sweep returned zero consumers; both subnets and dedicated route table deleted.
A4-F05	Medium	Default VPC security group contained active inbound/outbound permissions.	CLOSED - Default SG sanitized to zero rules.
A4-F06	Low/Med	Residual FSx pilot client security group and stale SMB relationship remained after pilot retirement.	CLOSED - stale reference removed and pilot SG deleted.

Finding closure result: all six A4 findings are closed. No open High or Medium findings remain.

4. Residual Observations

Observation	Assessment / treatment
Permissive default NACL	The default NACL permits all inbound and outbound traffic. This is retained as an observation, not a failed control, because routing and stateful security groups provide the active segmentation. Complex custom NACLs are not introduced without a workload-driven need.
Unused permanent public tier	Two public subnets remain empty. They may be retained as a reserved ingress/network tier for a future ALB/WAF pattern, but public compute should not be placed there by default.
No VPC endpoints	Acceptable for the current workload profile because no EC2, VPC-attached Lambda, ECS or EKS consumers require private AWS API access. Reassess when application workloads are introduced.
FSx availability model	Current evidence suggests a single-subnet FSx placement. This is not an A4 segmentation defect and should be assessed under A6 Backup & Recovery / availability objectives.

5. Network Visibility and Logging

Control	Validated state
Flow-log scope	Clinic VPC resource
Traffic type	ALL
Aggregation interval	60 seconds
Flow-log status	ACTIVE
Delivery status	SUCCESS with no delivery error
Destination	Dedicated S3 bucket in the Log Archive account
Object delivery	Recent non-zero .log.gz flow-log objects verified under the expected AWSLogs/vpcflowlogs/ap-east-1 hierarchy
S3 public access	All four S3 Block Public Access settings enabled
Versioning	Enabled
Encryption	SSE-KMS with a customer-managed KMS key

This closes the original network-telemetry gap and provides centralized evidence suitable for incident investigation and future traffic analysis.

6. Reachability / Attack-Path Validation

Validation path	Expected security behavior	Observed result	Assessment
Internet Gateway -> FSx ENI, TCP/445	Blocked	NetworkPathFound = false	PASS
Internet Gateway -> AD controller ENI, TCP/389	Blocked	NetworkPathFound = false	PASS
FSx ENI -> AD controller ENI, TCP/389	Reachable	NetworkPathFound = true	PASS

The blocked Internet tests were explained by private-IP/Internet-Gateway conditions and security-group mismatch, while the successful internal test traversed the FSx ENI, Clinic-NonProd-Group, the Directory Service controller security group, and the AD ENI. This validates both confidentiality-oriented isolation and required east-west functionality.

7. Evidence Index

Evidence	Purpose
E03	Subnet segmentation baseline
E04	Public/private route segmentation
E05	Sensitive ENIs private-only
E06	FSx private-subnet placement
E07	Directory Service private multi-AZ placement
E08	FSx pilot subnets - zero dependencies
E09	FSx pilot public tier retired
E10	Security-group rules baseline
E11	NACL rules baseline
E12	Default security group sanitized
E13	FSx pilot security group removed
E14	VPC endpoint inventory
E15	VPC-attached Lambda inventory
E16	VPC EC2 private-service consumers
E17	ECS cluster inventory
E18	EKS cluster inventory
E19	VPC Flow Log configuration
E20	VPC Flow Log S3 delivery
E21	Flow-log bucket public-access controls
E22	Flow-log bucket versioning
E23	Flow-log bucket encryption
E24	Internet -> FSx SMB reachability
E25	Internet -> AD LDAP reachability
E26	FSx -> AD LDAP reachability

Evidence preservation note: raw JSON evidence may contain AWS account identifiers, ARNs, resource IDs, and key identifiers. Retain raw evidence privately; create sanitized copies before public portfolio publication.

8. Final Decision

A4 Network Security is assessed as **PASS** and is formally closed. The current clinic Non-Production network has no unresolved High or Medium network-security findings. Residual observations are documented and either accepted for the present workload profile or transferred to the appropriate later mission section.

Proceed to A5 - Data Protection / Encryption.

MISSION 2 - A5.8

Final Data Protection & Encryption Assessment

Clinic Non-Production AWS Environment | ap-east-1 | 8 September 2026

FINAL RESULT	PASS	RESIDUAL RISK	LOW
Open High findings	0	Open Medium findings	0
Closed / mitigated findings	4	Residual observations	3

Assessment conclusion

A5 Data Protection & Encryption is assessed as **PASS**. The clinic file system is encrypted with a customer-managed KMS key, KMS administration has been separated from ordinary account administration, file-access auditing is enabled, S3 public-access guardrails are enforced at account level, the dedicated Flow Logs bucket requires TLS, and no additional unencrypted persistent data stores were identified.

No High or Medium A5 security finding remains open. Residual items are observations or follow-up controls rather than evidence of an active data-protection failure. The most important carry-forward items are mandatory SMB encryption enforcement verification and FSx backup/resilience review in A6.

Assessment scope

A5 section	Control area	Result
A5.1	Data asset and encryption baseline	PASS
A5.2	KMS key management and rotation	PASS
A5.3	FSx / file data protection	PASS + observation
A5.4	S3 data protection	PASS
A5.5	Secrets and sensitive configuration	PASS
A5.6	Other storage encryption	PASS
A5.7	Encryption in transit	PASS + observation
A5.8	Final assessment	PASS

1. Data Asset & Encryption Baseline

The data inventory showed a small and well-bounded Non-Prod footprint. The primary clinic data store is Amazon FSx for Windows File Server. No EBS volumes, RDS instances, EFS file systems, DynamoDB tables, or Secrets Manager secrets were present in the reviewed Region. The only SSM parameter observed was AWS Inspector service metadata, not a clinic credential or secret.

Asset	Observed state	Assessment
FSx Windows	SSD, AVAILABLE, encrypted with clinic CMK	PASS
EBS / RDS / EFS	No resources discovered	PASS
DynamoDB	No tables discovered	PASS
Secrets Manager	No secrets discovered	PASS
SSM Parameter Store	Inspector metadata only; no sensitive clinic parameter identified	PASS
S3 Non-Prod	Residual test bucket assessed and retired	PASS

2. KMS Key Management & Separation of Duties

The clinic FSx file system uses a **customer-managed**, symmetric KMS key with purpose-specific alias **alias/clinic-fsx-nonprod**. The key is enabled and automatic rotation is enabled on a 365-day period.

The initial key policy created a material separation-of-duties gap: the same administrative identity could administer the key, encrypt/decrypt data, generate data keys, and manage grants. The administrator was also a member of a group with AdministratorAccess, and the key policy permitted account-level IAM delegation.

Remediation introduced the dedicated **Clinic-KMS-Key-Administrator** role. The post-remediation key policy explicitly names this role for key administration and removes the generic IAM delegation and direct ordinary-administrator key-use statements. The role does not include Encrypt, Decrypt, GenerateDataKey, or ReEncrypt permissions.

FSx and AWS Backup service grants remained intact and resource-constrained. The ordinary SSO administrator was then verified to receive AccessDenied for direct access to the sensitive CMK, while the dedicated KMS role retained required key-management access.

Control	Before	After
Key administration	Ordinary administrator	Dedicated KMS administrator role
Cryptographic use by ordinary admin	Allowed	Denied
Generic IAM delegation	Present	Removed
FSx service grants	Present	Preserved
Backup service grant	Vault-constrained	Preserved
FSx availability	AVAILABLE	AVAILABLE

3. A5 Security Findings & Closure

All security findings discovered during A5 were either remediated or mitigated. No High or Medium finding remains open.

ID	Severity	Finding	Disposition
A5-F01	MEDIUM	FSx CMK separation-of-duties gap: ordinary administrator had both key-management and cryptographic permissions.	CLOSED. Dedicated KMS administrator role introduced; generic delegation and direct use removed; negative control test passed.
A5-F02	MEDIUM	Temporary KMS-admin STS credentials were exposed during evidence capture.	MITIGATED / CLOSED. Older role sessions were revoked with an explicit deny; subsequent fresh session was verified. Temporary revocation policy may be removed only after the exposed session has expired.
A5-F03	MEDIUM	FSx file and file-share access auditing was disabled.	CLOSED. SUCCESS_AND_FAILURE auditing enabled for file and share access with CloudWatch Logs destination; FSx remained AVAILABLE.
A5-F04	MEDIUM	Account-level S3 Block Public Access was not configured.	CLOSED. All four account-level public-access block controls enabled and verified.

4. Positive Security Controls

Control	Validated result
Encryption at rest	FSx protected with a customer-managed KMS key; no unencrypted residual storage discovered.
Key governance	Purpose-specific key alias, enabled key, 365-day automatic rotation, dedicated KMS administrator role.
File-access auditing	FSx file and file-share audit levels set to SUCCESS_AND_FAILURE.
S3 public exposure prevention	Bucket-level and account-level S3 Block Public Access enforced; residual test bucket retired.
S3 ownership	BucketOwnerEnforced observed on reviewed test bucket; no external ACL grant.
Flow Logs bucket transport	Explicit DenyInsecureTransport policy denies all S3 requests when aws:SecureTransport=false.
Secrets hygiene	No Secrets Manager secrets, no sensitive SSM parameters, no CodeBuild/ECS/launch-template secret path discovered.

5. Residual Observations & Follow-Up

The items below do not represent open A5 security findings, but they should remain visible in the project record.

ID	Observation	Treatment
A5-O02	The FSx CMK retains an intentional cross-account Backup-account principal for backup copy operations. The AWS Backup grant itself is tightly constrained to the clinic FSx backup vault.	Review destination Backup-account IAM least privilege during A6. Do not remove the working cross-account backup path without a replacement.
A5-O03	FSx SMB encryption capability is supported, but server-wide mandatory encryption enforcement (EncryptData / RejectUnencryptedAccess) was not directly verified because no private Windows management host exists.	Carry as verification gap. Validate from an approved private Windows administrative path when operationally justified.
A5-O05	AWS Control Tower NotificationForwarder Lambda stores only sns_arn metadata and uses default Lambda environment encryption.	No remediation required; non-secret AWS-managed landing-zone metadata.

A6 carry-forward: FSx backup and resilience

A5 evidence confirms the FSx deployment type is **SINGLE_AZ_2** and FSx-native automatic backup retention is set to **0** days. These are not A5 encryption failures because the design appears to rely on centralized AWS Backup, but they require explicit A6 validation of recovery points, retention, vault protection, cross-account copy, restore testing, and RTO/RPO suitability.

Data-protection posture after remediation

Layer	Post-remediation state
Data at rest	Encrypted with customer-managed key for primary clinic file data.
Key control	Dedicated administration path; ordinary administrator denied direct CMK access.
Auditability	File and share access auditing enabled to CloudWatch Logs.
Object storage	No residual Non-Prod application S3 bucket; account public-access guardrail enabled.
Transport security	S3 log bucket enforces TLS; SMB capability present, mandatory server-wide enforcement not directly verified.
Secrets	No material secret-storage gap identified.

6. Evidence Index

The final assessment is supported by machine-readable JSON evidence and selected command-output evidence collected during A5. The most material artifacts are listed below.

Evidence	Purpose
E01	FSx encryption baseline and deployment type
E09-E13	FSx CMK metadata, alias, rotation, key policy and grants baseline
E14-E16	Administrator IAM baseline, effective KMS simulation and group policies
E18-E23	Dedicated KMS role validation, post-remediation key policy, FSx health and grants
E24-E25	FSx data-protection configuration and enabled file-access auditing
E26-E33	S3 test-bucket assessment, ownership/access controls, account public-access guardrail
E34-E37	Lambda/CodeBuild/ECS/launch-template sensitive-configuration inventory
E38-E44	Residual storage and messaging encryption sweep
E45-E48	Flow Logs S3 TLS policy and application transport-surface inventory

7. Final A5.8 Decision

A5 FINAL RESULT	PASS
Open High findings	0
Open Medium findings	0
Residual risk	LOW
Readiness	Proceed to A6 - Backup & Recovery Security

A5 demonstrates a defensible data-protection posture for the current Non-Prod clinic workload. The primary data store is encrypted with a customer-managed key, key-management authority has been constrained, audit logging has been enabled, S3 preventive controls have been strengthened, transport controls were validated where directly observable, and no additional unencrypted data stores or material secret-handling gaps were found.

Recommendation: close A5 and proceed to A6. A6 should prioritize the confirmed Single-AZ FSx deployment, centralized AWS Backup coverage, backup-vault controls, cross-account copy permissions, retention, restore testing, and RTO/RPO validation.

END OF A5.8 ASSESSMENT

HEALTHCARE CLOUD SECURITY ENGINEERING PROJECT

A6.8

Final Backup & Recovery Security Assessment

Secure AWS Migration for a Clinic Management System

Assessment date	16 September 2026
Primary workload region	ap-east-1 (Hong Kong)
Backup isolation region	ap-southeast-2 (Sydney)
Primary workload	Amazon FSx for Windows File Server - Clinic NonProduction
Overall A6 verdict	PASS / CLOSED
Residual risk posture	LOW - documented operational and architecture limitations

Assessment purpose

To provide the final evidence-based backup, cross-account copy, encryption, immutability, restore, functional recovery, deletion-resilience, remediation, and residual-risk position for Mission 2 Event A6.

Prepared as a portfolio-grade security engineering assessment, not a backup-enablement checklist.

Document Control

Field	Value	Field	Value
Document ID	M2-A6.8-FINAL	Version	1.0
Assessment owner	Project Security Engineering	Assessment date	2026-09-16
Scope	A6.1-A6.8	Environment	Clinic NonProduction
Classification	Portfolio / Internal Engineering Evidence	Status	Final
Primary account	REDACTED - Clinic NonProduction	Backup account	REDACTED
Primary region	ap-east-1 (Hong Kong)	Backup region	ap-southeast-2 (Sydney)

Contents

1	Executive Assessment
2	Assessment Scope, Architecture and Method
3	A6 Control Objectives and Acceptance Criteria
4	A6 Event-by-Event Assessment
5	Backup Architecture, Scheduling and Retention
6	Cross-Account Immutability and KMS Governance
7	Restore and Functional Recovery Validation
8	Deletion / Misconfiguration Resilience
9	Findings Register and Closure Position
10	Residual Risk and Operational Limitations
11	Evidence Quality, Limitations and Auditability
12	Final Backup & Recovery Verdict and A8 Readiness
	Appendix A Evidence Register
	Appendix B Key Resource and Control Inventory
	Appendix C Engineering Lessons and Portfolio Value
	Appendix D Detailed Finding Narratives

1. Executive Assessment

A6 - Backup & Recovery Security was executed as a recovery-engineering exercise across the Clinic NonProduction AWS environment. The event did not stop at confirming that scheduled backups existed. It validated schedule reliability, cross-account copies, Vault Lock behavior, KMS least privilege, real FSx restoration, Active Directory integration, SMB functionality, audit logging after restore, secure cleanup, deletion resilience, and operational regression after remediation.

Final verdict

PASS / CLOSED. All MEDIUM findings identified within A6 were remediated and revalidated. The destination Compliance Vault Lock matured beyond its grace period on 16 Sep 2026, closing the last time-dependent finding. Remaining items are LOW residuals or documented limitations rather than open remediation failures.

Dimension	Final position	Assessment
Backup schedule	05:00 / 17:00 SGT; Tuesday maintenance-risk regression passed	PASS
Source retention	14 days; Governance Vault Lock 14-30 days	PASS
Cross-account copy	Dedicated Backup account / Sydney; 30-day copy retention	PASS
Destination immutability	Compliance Vault Lock matured; 30-90 day bounds	PASS
KMS governance	Source and destination CMKs hardened to exact service roles / grants	PASS
Actual restore	FSx restored successfully after KMS CreateGrant remediation	PASS
Functional recovery	AD, DNS, TCP/445, SMB share, write/read/hash/delete validated	PASS
Audit after recovery	Restored audit config re-applied and Event ID 5140 observed	PASS
Deletion resilience	Tag-based selection + MFA-protected destructive deletion	PASS
Open residual risk	No unresolved High/Medium; documented LOW limitations only	LOW

Assessment conclusion: A6 demonstrates a defensible recovery lifecycle: discover -> fail safely -> identify root cause -> remediate -> restore -> functionally validate -> prove logging -> clean up -> harden against recurrence -> revalidate operationally.

2. Assessment Scope, Architecture and Method

The primary workload is an Amazon FSx for Windows File Server in the Clinic NonProduction account and Hong Kong region. Scheduled AWS Backup recovery points are stored locally and copied cross-account to an isolated Backup account in Sydney. Source and destination use customer-managed KMS keys. The final architecture uses a mutable-but-protected operational copy in the source account and a hardened immutable copy in the Backup account.

Element	Value / decision
Workload account	REDACTED - Clinic NonProduction
Backup account	REDACTED
Primary region	ap-east-1 (Hong Kong)
Backup isolation region	ap-southeast-2 (Sydney)
Current FSx	REDACTED - Windows, SINGLE_AZ_2, 32 GiB SSD
Directory	REDACTED - corp.clinicnonprod.com

Element	Value / decision
Backup plan	59a8bde5-79f0-4d6d-b849-ff44aab94d32 - clinic-fsx-12h-nonprod
RPO / RTO target context	12 hours / 24 hours
Observed infrastructure restore duration	~26m32s; not claimed as end-to-end service RTO

2.1 Assessment method

- Capture direct AWS API evidence before remediation and after every material change.
- Distinguish configuration proof from operational proof; scheduled jobs and runtime restore behavior were required for closure.
- Prefer least-privilege service-role and grant permissions over broad account delegation.
- Use actual restore and SMB I/O validation rather than assuming a recovery point is usable.
- Treat post-restore security controls as separate validation targets; restored data alone does not prove a secure recovered system.
- Preserve failed jobs and failed restore attempts as evidence where they reveal control dependencies.
- Use safer IAM simulation / direct state checks instead of destructive negative testing where an actual delete would create unnecessary risk.
- Re-run scheduled and cross-account operations after remediation to demonstrate regression safety.

3. A6 Control Objectives and Acceptance Criteria

Control	Objective	Acceptance criterion	Final
BR-01	Reliable scheduled backup	Current FSx backed up every 12h without recurring FSx maintenance conflict	PASS
BR-02	Retention / immutability	Source protected against routine deletion; destination permanently locked within approved bounds	PASS
BR-03	Encrypted cross-account copy	Copy succeeds using CMKs with least-privilege service access	PASS
BR-04	Recoverability	A real FSx recovery point can create a usable file system	PASS
BR-05	Functional recovery	Recovered FSx joins AD and supports private SMB read/write/delete operations	PASS
BR-06	Post-restore security	Audit logging and network/KMS controls re-applied and operationally proven	PASS
BR-07	Deletion resilience	Replacement resources remain protectable without exact-ARN dependency; destructive deletion guarded by MFA	PASS

4. A6 Event-by-Event Assessment

Event	Focus	Assessment outcome	Status
A6.1	Backup architecture baseline	Inventoried current FSx, plan, vaults, retention, copy topology, service roles and KMS dependencies.	COMPLETE
A6.2	Schedule and maintenance resilience	Found Tuesday maintenance conflict; moved schedule to 05:00/17:00 SGT; final Tuesday regression completed successfully.	COMPLETE

Event	Focus	Assessment outcome	Status
A6.3	Vault immutability	Configured destination Compliance Vault Lock and later verified post-lock-date maturation; source Governance lock added later.	COMPLETE
A6.4	Cross-account KMS regression	KMS hardening caused copy DescribeKey failure; exact service-role permission restored and copy revalidated.	COMPLETE
A6.5	KMS least privilege / copy path	Removed broad source/destination account delegation; validated exact service-linked roles and constrained grants.	COMPLETE
A6.6	Restore and recovery validation	Real FSx restore, KMS remediation, audit remediation, AD/SMB I/O proof, audit-event proof and secure cleanup.	COMPLETE
A6.7	Deletion / misconfiguration resilience	Replaced exact-ARN backup selection with tag-based selection; MFA guardrail applied; source Governance lock enabled.	COMPLETE
A6.8	Final Backup & Recovery Security Assessment	Consolidates final control state, findings, residuals, evidence quality and readiness.	FINAL

5. Backup Architecture, Scheduling and Retention

5.1 Final architecture

Recovery path

Clinic FSx (Hong Kong) -> source AWS Backup vault -> cross-account / cross-region copy -> isolated Backup account vault (Sydney). The source copy supports fast operational recovery; the destination copy provides stronger isolation and permanent compliance-mode immutability.

Component	Final state
Backup plan	clinic-fsx-12h-nonprod
Schedule	cron(0 5,17 * * ? *) / Asia/Singapore
Start / completion window	60 / 720 minutes
Source vault	clinic-fsx-nonprod-vault
Source lifecycle	14 days
Source Vault Lock	Governance; Locked=true; Min=14; Max=30
Destination vault	clinic-central-backup-vault-v2
Copy lifecycle	30 days
Destination Vault Lock	Compliance; Locked=true; Min=30; Max=90; matured 16 Sep 2026
Backup selection	FSx wildcard + Environment=NonProd + BackupPolicy=clinic-fsx-12h

5.2 F01 - schedule / maintenance conflict

Historical backup evidence captured recurring Tuesday failures because the former 08:00/20:00 SGT schedule was inside or too close to the FSx weekly maintenance window. The rule was changed to 05:00/17:00 SGT with a 60-minute start window. The final Tuesday regression on 15 Sep showed both the 05:00 and 17:00 jobs in COMPLETED state, each with a recovery point and no status error.

Evidence state	Result
Pre-remediation	Tuesday backup failed: inside or too close to weekly FSx maintenance window
Remediation	Schedule 05:00 / 17:00 SGT; StartWindow=60
Final operational confirmation	Both Tuesday jobs COMPLETED on 15 Sep 2026
Finding	A6-F01 - CLOSED

6. Cross-Account Immutability and KMS Governance

6.1 F02 - destination Compliance Vault Lock

The destination vault was initially unlocked. Compliance Vault Lock was configured with 30-90 day retention and a seven-day grace period. A 30-day copy completed successfully while the lock was configured, proving lifecycle compatibility. Final verification was captured after the LockDate, not merely during the grace period.

Final verification attribute	Value
Verification time (UTC)	2026-09-16T11:09:37Z
Vault	clinic-central-backup-vault-v2
Recovery points	37
Locked	true
MinRetentionDays	30
MaxRetentionDays	90
LockDate	2026-09-16T07:06:23.196000+00:00
Destination CMK	f3b458b5-3bfd-4142-9435-8a97b8a0aede
Finding	A6-F02 - CLOSED

Why this is closure evidence

Locked=true alone existed during the grace period. The decisive evidence is that the verification timestamp is later than LockDate while the approved 30-90 day bounds remain in place. The Compliance Vault Lock configuration is therefore beyond its changeable grace period.

6.2 KMS copy-path regression and least privilege

KMS hardening exposed a real dependency: AWS Backup could no longer copy a recovery point because AWSBackupDefaultServiceRole was denied kms:DescribeKey on the source CMK. CloudTrail identified the exact principal. The remediation added DescribeKey only to that source Backup service role, then subsequent work replaced broad Backup-account delegation with the exact destination AWSServiceRoleForBackup and constrained CreateGrant behavior. Destination-key policy was similarly reduced to a dedicated key-administrator role plus exact service-linked Backup access.

Finding	Issue	Closure basis	Status
A6-F03	Destination CMK rotation disabled	Rotation enabled and revalidated	CLOSED
A6-F04	Source KMS hardening broke cross-account copy	Exact source Backup role DescribeKey; failed RP retried successfully	CLOSED
A6-F05	Destination CMK broad account delegation	Dedicated KMS admin role + exact Backup SLR permissions; copy succeeded	CLOSED
A6-F06	Source CMK broad Backup-account delegation	Exact destination Backup SLR DescribeKey/CreateGrant; copy succeeded	CLOSED

Successful regression evidence includes E38 (copy after KMS fix), E51 (copy after source delegation hardening), and E56 (copy after destination KMS hardening). These tests demonstrate that least-privilege changes preserved the recovery path rather than merely making policies look narrower.

7. Restore and Functional Recovery Validation

7.1 Actual FSx restore

A6.6 used a real source recovery point rather than a simulated restore. The first accepted restore request failed at KMS because AWSBackupDefaultServiceRole lacked kms:CreateGrant on the source CMK. A constrained CreateGrant permission with kms:GrantIsForAWSResource=true was added. The retry completed successfully and created restored FSx

REDACTED

Restore stage	Result
Initial corrected restore request	Accepted by AWS Backup, then FAILED at KMS CreateGrant
Remediation	Allow source AWSBackupDefaultServiceRole kms:CreateGrant only for AWS-resource grants
Retry	COMPLETED / 100%
Created resource	REDACTED
Observed infrastructure restore time	~26 minutes 32 seconds
RTO interpretation	Infrastructure restore duration only; not claimed as full application/service RTO
Finding	A6-F07 - CLOSED

7.2 Post-restore security-control loss

The restored FSx was AVAILABLE and correctly placed on the private network with the expected source CMK, but file-access and file-share audit levels were DISABLED. The source system had both audit levels set to SUCCESS_AND_FAILURE. This created a genuine recovery-security gap: restored data could have been promoted without the audit trail required by the hardened baseline.

The restored filesystem was updated to SUCCESS_AND_FAILURE for both audit categories. E68 validated the configuration and E74 later captured Windows Security Event ID 5140 in the restored FSx audit stream during the SMB test, proving the control was operational rather than merely configured.

Validation	Final state
FileAccessAuditLogLevel	SUCCESS_AND_FAILURE
FileShareAccessAuditLogLevel	SUCCESS_AND_FAILURE
Destination	/aws/fsx/windows -> restored FSx audit stream
Runtime event proof	Windows Security Event ID 5140 during restored SMB share access
Finding	A6-F08 - CLOSED

7.3 Private Windows client and SMB functional test

A temporary Windows Server 2022 EC2 instance was created in a private subnet with no public IP and no RDP ingress. Systems Manager and Directory Service PrivateLink endpoints provided management and domain-join API connectivity. The client joined corp.clinicnonprod.com and tested both the source and restored FSx over TCP/445.

Test	Observed result	Assessment
Domain membership	PartOfDomain=True / corp.clinicnonprod.com	PASS
Source DNS / SMB	Private DNS resolved; TCP/445=True	PASS
Restored DNS / SMB	Private DNS resolved; TCP/445=True	PASS
Source share	Accessible	PASS
Restored share	Accessible	PASS
Restored write/read	Temporary file written and read back correctly	PASS
SHA-256	5B8D8F2685FD5BE54CB0FF98AB8D973856F95B106C12D920BDDCEE6CC19FB45E	PASS
Cleanup probe	Temporary test file deleted; ProbeDeleted=True	PASS

Recovery proof chain

Backup recovery point -> actual FSx restore -> KMS-backed filesystem -> AD integration -> private DNS -> TCP/445 -> SMB share -> write/read/hash/delete -> audit event.

7.4 Secure cleanup

The temporary test environment was removed after validation. The temporary SMB ingress rule was revoked, the Windows instance and PrivateLink endpoints were removed, the temporary IAM role/profile and security groups were deleted, the restored FSx was deleted without creating an unnecessary final backup, and KMS grants scoped to the restored FSx were confirmed absent. The temporary AD computer object was also confirmed deleted.

Cleanup control	Final evidence
Clinic FSx SG	Ingress=[]
Restore-test ENIs	None remaining
Restored FSx	Deleted
Temporary EC2 / endpoints / SGs / IAM	Deleted / absent
Restored-FSx KMS grants	RemainingRestoredFSxGrants=[]
Temporary AD computer object	Confirmed deleted

8. Deletion / Misconfiguration Resilience

8.1 Accidental deletion evidence

CloudTrail preserved historical DeleteFileSystem events executed by Clinic-NonProd-Administrator with skipFinalBackup=true. This evidence was treated as a real operator-error / destructive-administration scenario rather than hidden. It drove two resilience improvements: replacement-safe backup selection and an MFA-dependent deletion guardrail.

8.2 F09 - replacement-safe backup selection

The original AWS Backup selection targeted the exact FSx ARN. Recreating an FSx changes its ARN, so a replacement could run without scheduled protection until someone manually updated the selection. The current FSx was tagged with Environment=NonProd and BackupPolicy=clinic-fsx-12h, a new wildcard FSx selection with those tag conditions was created, and the exact-ARN selection was removed.

Control	Final state
Resource scope	REDACTED
Condition 1	aws:ResourceTag/Environment = NonProd
Condition 2	aws:ResourceTag/BackupPolicy = clinic-fsx-12h
Obsolete exact-ARN selection	Removed
Operational regression	10 Sep 05:00 SGT scheduled backup COMPLETED and created recovery point
Finding	A6-F09 - CLOSED

8.3 F10 - destructive deletion without MFA

IAM simulation showed fsx:DeleteFileSystem was allowed to Clinic-NonProd-Administrator through AdministratorAccess inherited from the Clinic-NonProd-Administrators group, while the user had no MFA device. An inline DenyFSxDeletionWithoutMFA policy was applied using BoolIfExists on aws:MultiFactorAuthPresent. Simulation then returned explicitDeny without MFA and allowed with MFA. MFA was subsequently enrolled and the final non-MFA simulation remained explicitDeny.

Control state	Result
Permission source	AdministratorAccess via Clinic-NonProd-Administrators group
Pre-remediation MFA	No MFA device
Guardrail	Explicit deny fsx:DeleteFileSystem when MFA=false/absent
Without MFA simulation	explicitDeny
With MFA simulation	allowed
MFA enrollment	Clinic-Protect-MFA enabled 9 Sep 2026
Final non-MFA regression	explicitDeny
Finding	A6-F10 - CLOSED

8.4 Source Governance Vault Lock

A6-O18 identified that source recovery points remained mutable while the isolated destination was the primary immutable layer. The project elected to improve this LOW risk by applying Governance Vault Lock to the source vault with 14-30 day bounds. This reduces routine deletion risk while retaining an authorized administrative escape path appropriate for NonProduction.

9. Findings Register and Closure Position

ID	Finding	Final disposition	Residual
F01	Backup schedule conflicted with FSx weekly maintenance window	CLOSED / REMEDIATED / OPERATIONALLY VALIDATED	LOW
F02	Destination backup vault lacked permanent immutability	CLOSED / COMPLIANCE LOCK MATURED	LOW
F03	Destination KMS rotation disabled	CLOSED / REMEDIATED	LOW
F04	Source KMS hardening broke cross-account copy DescribeKey path	CLOSED / REMEDIATED / COPY REVALIDATED	LOW
F05	Destination CMK broad account delegation	CLOSED / LEAST-PRIVILEGE HARDENED	LOW
F06	Source CMK broad Backup-account delegation	CLOSED / LEAST-PRIVILEGE HARDENED	LOW
F07	Restore blocked by missing source CMK CreateGrant	CLOSED / REMEDIATED / RESTORE COMPLETED	LOW
F08	Restored FSx lost audit configuration	CLOSED / REMEDIATED / RUNTIME AUDIT PROVEN	LOW
F09	Exact-ARN backup selection not resilient to FSx replacement	CLOSED / TAG-BASED SELECTION / JOB VALIDATED	LOW
F10	Human admin could delete FSx without MFA	CLOSED / MFA + EXPLICIT DENY VALIDATED	LOW

9.1 Notable observations and closure notes

- A6-007 - AWS Config KMS DescribeKey denial was carried into A7 rather than remediated blindly; A7 later addressed Config prerequisite / coverage issues.
- A6-008 - Backup-account KMS administration is logically separated by role, but not an independent-human dual-control model. Retained as LOW architectural residual.
- A6-009 - The Backup account is an isolated repository, not a pre-staged DR workload environment. Full source-account-loss recovery still requires infrastructure reconstitution before service restore.
- A6-013 - Restored FSx did not inherit source tags. Recovery runbooks must reapply tagging / backup-selection metadata before production promotion.
- A6-016 - No pre-existing canary file was available for historical byte-for-byte comparison. A future drill should seed a known file before backup and compare its hash after restore.
- A6-017 - Temporary AD test computer object was confirmed deleted; no further action.
- A6-018 - Source-vault mutability was voluntarily remediated with Governance Vault Lock 14-30 days.

10. Residual Risk and Operational Limitations

Residual / limitation	Consequence	Review trigger
Logical rather than independent-human KMS admin separation	Same trusted administrator may still assume privileged role; weaker than true two-person control	Production separation-of-duties requirement
Backup account is not a pre-staged DR environment	Cross-account data is protected, but infrastructure must be rebuilt before service restore	Production DR architecture / tighter RTO
Restored tags are not automatic	Recovered replacement could miss governance or backup selection if runbook step is skipped	Any restore promoted as replacement
No historical canary-file hash proof	Functional recoverability proven, but historical content equivalence was not demonstrated with a seeded file	Next recovery exercise
Single-AZ FSx architecture	Accepted NonProduction availability characteristic; backup recovery mitigates but does not eliminate outage duration	Production architecture design

11. Evidence Quality, Limitations and Auditability

The A6 evidence set is strong because it contains direct AWS API state, CloudTrail principal-level evidence, failed and successful copy jobs, a real restore, runtime Windows/SMB output, actual Windows Security audit events, IAM policy simulation, cleanup evidence, and time-delayed Vault Lock maturation proof. This goes beyond configuration screenshots and demonstrates control behavior.

Evidence quality factor	Assessment
Directness	High - conclusions are primarily backed by AWS API or runtime service output
Recoverability proof	High - actual FSx restore plus private SMB functional validation
Regression quality	High - KMS hardening, tag-based selection and schedule changes were followed by successful operations
Immutability proof	High - final verification timestamp is after destination LockDate
Cleanup proof	High - network state, resource absence and KMS grant absence validated
Known limitation	No historical canary file; observed restore time is infrastructure duration, not end-to-end application RTO
Portfolio suitability	High - includes failures, root-cause analysis, remediation, negative tests and evidence-backed closure

12. Final Backup & Recovery Verdict and A8 Readiness

Decision area	Verdict
A6 completion	PASS / CLOSED
Unresolved Critical findings	0
Unresolved High findings	0
Unresolved Medium findings	0
Open material remediation actions	0
Destination Compliance Vault Lock	MATURED / IMMUTABLE
Actual restore / SMB functional test	PASS
Ready to proceed to A8	YES
Recommended A8 emphasis	Mission 2 readiness gates, operational runbooks, cutover / rollback control, final evidence packaging

Final sign-off statement

Mission 2 Event A6 demonstrates that the Clinic NonProduction AWS environment has a validated backup and recovery posture: backups operate on schedule, recovery points are protected by layered Vault Lock controls, cross-account encryption uses constrained KMS paths, actual FSx restoration and SMB functionality were proven, post-restore security controls were re-applied and verified, destructive administration was hardened, and all material A6 findings are closed. The environment is ready to proceed to A8 readiness assessment.

Appendix A - Evidence Register

The register lists principal A6 evidence families. Individual files preserve exact before/after, failed/successful, regional, account, or runtime state.

Evidence family	Purpose
E01-E10	Baseline identity, FSx, backup plan, vaults and job history; maintenance-window failure evidence
E11-E14	Backup-plan schedule remediation and final rule validation
E28-E32	Destination recovery points, encryption, lifecycle and cross-account copy history
E33-E38	KMS DescribeKey denied principal, source key-policy repair and successful retry
E39-E42	Destination vault pre-lock, Compliance lock, copy compatibility and final post-LockDate verification
E43-E56	Cross-account architecture, KMS CloudTrail usage, source/destination least-privilege hardening and regression copies
E57-E63	Restore metadata / preflight, first KMS failure, CreateGrant remediation and successful restore
E64-E68	Restored FSx state, network/KMS grant validation and audit-configuration remediation
E69-E74	Private Windows client, domain join, SMB functional test, ENI/DNS consistency and runtime audit event
E75-E78	Secure cleanup and restored-FSx KMS grant removal
E79-E82	Historical deletion evidence, exact-ARN selection weakness, protection status and vault resilience
E83-E85b	Backup tags, tag-based selection creation and obsolete selection removal
E86-E93	IAM/MFA posture, effective permission simulation, deletion guardrail and MFA enrollment
E94-E95	Source Governance Vault Lock before/after state
E96	Operational proof that tag-based selection produced the next scheduled backup
E97a-E97b	Final Tuesday schedule configuration and two successful maintenance-risk-period jobs

Appendix B - Key Resource and Control Inventory

Asset / control	Identifier / state
Current FSx	REDACTED
FSx DNS	amznfsxylk5ew0w.corp.clinicnonprod.com
Directory	REDACTED / corp.clinicnonprod.com
Source FSx SG	REDACTED
Backup plan	59a8bde5-79f0-4d6d-b849-ff44aab94d32 / clinic-fsx-12h-nonprod
Source vault	clinic-fsx-nonprod-vault
Destination vault	clinic-central-backup-vault-v2
Source CMK	d49def22-0d89-485e-a04a-3c5206f5a3cb / alias/clinic-fsx-nonprod
Destination CMK	f3b458b5-3bfd-4142-9435-8a97b8a0aede
Source KMS admin role	Clinic-KMS-Key-Administrator
Destination KMS admin role	Clinic-Backup-KMS-Key-Administrator
Final tag-based selection	93dd87d2-0247-4c87-a22e-194e52681cca
Source Vault Lock	Governance / 14-30 days
Destination Vault Lock	Compliance / 30-90 days / matured
FSx audit log group	/aws/fsx/windows

Appendix C - Engineering Lessons and Portfolio Value

- A backup that exists is not necessarily recoverable. A6 required an actual restore and file-level SMB validation.
- KMS least-privilege hardening can break managed-service recovery paths. CloudTrail and failed jobs are essential for identifying the exact service principal and action needed.
- Post-restore security posture can differ materially from the source system. Audit configuration, tags, backup selection and other hardening must be treated as explicit recovery-runbook steps.
- Immutable backup design benefits from layered modes: Governance Lock on the operational source vault and Compliance Lock in a separate Backup account.
- Replacement resilience matters. Exact resource ARNs are fragile after deletion/recreation; controlled tags provide a more durable selection mechanism.
- Negative IAM simulation is safer and stronger than performing a destructive delete simply to prove a guardrail.
- Operational mistakes can become high-value engineering evidence when they are preserved, explained, remediated and regression-tested rather than hidden.
- Recovery timing must be stated precisely: ~26.5 minutes was observed for infrastructure restore, but it is not equivalent to application/service RTO.

Portfolio narrative

A6 demonstrates hands-on cloud security engineering across backup policy, KMS, cross-account isolation, immutable retention, restore troubleshooting, Windows/AD/SMB recovery testing, audit validation, IAM simulation, cleanup, and resilience against operator error.

Appendix D - Detailed Finding Narratives

This appendix preserves why each material A6 finding existed, why it mattered, how it was treated, and the basis for closure.

F01 - Backup schedule / FSx maintenance conflict

Aspect	Assessment
Issue / trigger	A Tuesday backup repeatedly failed because the schedule was inside or too close to the FSx weekly maintenance window.
Security / recovery significance	A predictable recurring backup failure reduces effective RPO assurance even if other runs succeed.
Treatment and closure basis	Moved to 05:00/17:00 SGT, reduced start window to 60 minutes, and later proved both Tuesday jobs completed successfully.
Primary evidence	E10, E11-E14, E97a-E97b
Final disposition	CLOSED / REMEDIATED / OPERATIONALLY VALIDATED

F02 - Destination vault immutability

Aspect	Assessment
Issue / trigger	The isolated destination vault initially had no permanent Vault Lock.
Security / recovery significance	A compromised or mistaken privileged path in the Backup account could otherwise weaken retention or delete recovery points.
Treatment and closure basis	Configured Compliance Vault Lock 30-90 days, proved 30-day copy compatibility, then waited through the grace period and verified state after LockDate.
Primary evidence	E39-E42
Final disposition	CLOSED / COMPLIANCE LOCK MATURED

F03 - Destination KMS rotation

Aspect	Assessment
Issue / trigger	Destination CMK rotation was disabled.
Security / recovery significance	Long-lived encryption keys should follow the approved key-rotation baseline.
Treatment and closure basis	Enabled rotation and retained the destination CMK as the encryption key for completed recovery points.
Primary evidence	Destination KMS configuration evidence
Final disposition	CLOSED / REMEDIATED

F04 - Source KMS regression on cross-account copy

Aspect	Assessment
Issue / trigger	Source KMS hardening removed a permission that AWS Backup needed, causing a copy to fail at kms:DescribeKey.
Security / recovery significance	Over-hardening can silently break the recovery path.
Treatment and closure basis	CloudTrail identified AWSBackupDefaultServiceRole; DescribeKey only was granted and the exact failed recovery point was copied successfully.
Primary evidence	E31, E33, E37-E38
Final disposition	CLOSED / REMEDIATED / COPY REVALIDATED

F05 - Destination CMK broad delegation

Aspect	Assessment
Issue / trigger	Destination key policy delegated broadly through the Backup account.
Security / recovery significance	Broad account delegation increases the number of principals that may become eligible for key use.
Treatment and closure basis	Created a dedicated key-admin role and exact AWSServiceRoleForBackup DescribeKey/CreateGrant permissions constrained to the FSx service; copy regression passed.
Primary evidence	E55-E56
Final disposition	CLOSED / LEAST-PRIVILEGE HARDENED

F06 - Source CMK broad Backup-account delegation

Aspect	Assessment
Issue / trigger	Source CMK policy trusted the Backup-account root for multiple cryptographic actions.
Security / recovery significance	Cross-account root delegation was wider than the actual managed-service copy path required.
Treatment and closure basis	Replaced broad delegation with the exact destination AWSServiceRoleForBackup and constrained grants; copy regression passed.
Primary evidence	E46, E51
Final disposition	CLOSED / LEAST-PRIVILEGE HARDENED

F07 - Restore blocked by missing CreateGrant

Aspect	Assessment
Issue / trigger	A real restore failed because AWSBackupDefaultServiceRole lacked kms:CreateGrant on the source CMK.
Security / recovery significance	A backup is not operationally recoverable if the restore service cannot obtain resource grants.
Treatment and closure basis	Added CreateGrant with kms:GrantIsForAWSResource=true and retried the restore successfully.
Primary evidence	E60-E63
Final disposition	CLOSED / RESTORE REVALIDATED

F08 - Restored FSx audit controls disabled

Aspect	Assessment
Issue / trigger	The restored FSx did not inherit SUCCESS_AND_FAILURE file/share audit settings.
Security / recovery significance	A recovered workload could return to service with weaker monitoring than the source baseline.
Treatment and closure basis	Re-applied audit levels, validated the new stream, and captured Event ID 5140 during SMB access.
Primary evidence	E64, E67-E68, E74
Final disposition	CLOSED / RUNTIME AUDIT PROVEN

F09 - Exact-ARN backup selection

Aspect	Assessment
Issue / trigger	Backup selection referenced the current FSx ARN exactly.
Security / recovery significance	Deleting/recreating FSx changes its ARN, creating a backup gap until manual selection repair.
Treatment and closure basis	Moved to FSx wildcard plus Environment/BackupPolicy tag conditions, removed old selection, and proved next scheduled backup completed.
Primary evidence	E80, E83-E85b, E96
Final disposition	CLOSED / TAG-BASED SELECTION VALIDATED

F10 - FSx deletion allowed without MFA

Aspect	Assessment
Issue / trigger	Human administrator had effective fsx:DeleteFileSystem through AdministratorAccess and no MFA device.
Security / recovery significance	Historical deletion evidence showed skipFinalBackup=true from a non-MFA session; the same capability remained active.
Treatment and closure basis	Added explicit deny when MFA is false/absent, enrolled MFA, and simulated both denied non-MFA and allowed MFA paths.
Primary evidence	E79, E86-E93
Final disposition	CLOSED / MFA + EXPLICIT DENY VALIDATED

END OF A6.8 FINAL BACKUP & RECOVERY SECURITY ASSESSMENT

HEALTHCARE CLOUD SECURITY ENGINEERING PROJECT

A7.8

Final Config & Compliance Assessment

Secure AWS Migration for a Clinic Management System

Assessment date	13 September 2026
Primary workload region	ap-east-1 (Hong Kong)
Approved recovery region	ap-southeast-1 (Singapore)
Control Tower home region	ap-southeast-2 (Sydney) - approved governance exception
Overall A7 verdict	PASS + APPROVED EXCEPTIONS / CLOSED
Residual risk posture	LOW, with documented conditional and architectural exceptions

Assessment purpose

To provide the final evidence-based governance, configuration, compliance, remediation, exception, and residual-risk position for Mission 2 Event A7.

Prepared as a portfolio-grade security engineering assessment, not a service-enablement checklist.

Document Control

Field	Value	Field	Value
Document ID	M2-A7.8-FINAL	Version	1.0
Assessment owner	Project Security Engineering	Assessment date	2026-09-13
Scope	A7.1-A7.8	Environment	Clinic NonProduction
Classification	Portfolio / Internal Engineering Evidence	Status	Final
Primary account	REDACTED - Clinic NonProduction	Management account	REDACTED
Security account	REDACTED	Log Archive account	REDACTED

Contents

- 1 Executive Assessment
- 2 Assessment Scope, Architecture and Method
- 3 A7 Control Objectives and Acceptance Criteria
- 4 A7 Event-by-Event Assessment
- 5 Detailed Guardrail Validation
- 6 Security Hub CSPM and Regional Drift Investigation
- 7 Tagging Compliance and Managed-Resource Exception
- 8 Remediation Validation
- 9 Findings Register and Closure Position
- 10 Exception Register and Residual Risk
- 11 Evidence Quality, Limitations and Auditability
- 12 Final Compliance Verdict and A8 Readiness

Appendix A Evidence Register

Appendix B Key Resource and Control Inventory

Appendix C Lessons Learned / Engineering Value

1. Executive Assessment

A7 - Config & Compliance was executed as a governance-engineering exercise across the Clinic NonProduction AWS environment. The event did not stop at enabling AWS Config or Security Hub. It established a chain of evidence from baseline discovery, configuration-state capture, preventive guardrail design, cross-account governance, regional drift detection, remediation, exception handling, and final regression validation.

Final verdict: PASS + APPROVED EXCEPTIONS / CLOSED.

The assessment found no unresolved HIGH or CRITICAL remediation item within the agreed A7 scope. All remediable findings were corrected and revalidated. Remaining deviations are either architecture-driven exceptions, Control Tower managed-resource exceptions, or condition-based service activation decisions, each with LOW residual risk and security-side approval where required.

Dimension	Final position	Assessment
Preventive governance	GR-01 through GR-07 validated in NonProduction	PASS
Regional governance	Hong Kong workload, Singapore recovery, Sydney governance-only exception	PASS + Exception
Configuration monitoring	AWS Config active; regional detective coverage validated and remediated	PASS
Security posture management	Security Hub CSPM centralized; high/critical drift investigated	PASS + Observation
Threat / vulnerability coverage	GuardDuty and Inspector Singapore gaps remediated	PASS
Tagging governance	HK compliant; SG remediable drift closed; 7 CT-managed resources excepted	PASS + Exception
Backup / log protection	Vault Lock, plan integrity, long log retention, privileged path controls	PASS
Open residual risk	No unresolved high/critical item; approved LOW residuals only	LOW

Assessment conclusion: A7 demonstrates a defensible security-engineering lifecycle: discover -> prove -> classify -> authorize -> remediate -> negative-test -> revalidate -> document residual risk.

2. Assessment Scope, Architecture and Method

The assessment covers the full A7 sequence within Mission 2 of the clinic migration project. The primary workload baseline is Hong Kong (ap-east-1). Singapore (ap-southeast-1) is the approved recovery region. Control Tower is actually homed in Sydney (ap-southeast-2), creating an architectural mismatch against the originally intended region strategy; this was formally analyzed and accepted rather than concealed.

Element	Value / decision
Workload account	REDACTED - Clinic NonProduction
Organization management	REDACTED

Element	Value / decision
Security delegated administration	REDACTED
Central log archive	REDACTED
Primary region	ap-east-1 (Hong Kong)
Recovery region	ap-southeast-1 (Singapore)
Control Tower home region	ap-southeast-2 (Sydney)
RPO / RTO	12 hours / 24 hours
Assessment period	A7 execution through 13 Sep 2026
Budget context	USD 10,000 / 3 years, including USD 1,000 contingency

2.1 Assessment method

1. Baseline the environment and identify control drift before changing resources.
2. Capture authoritative AWS API evidence for every material conclusion.
3. Differentiate preventive controls (SCPs, Block Public Access, Vault Lock) from detective controls (Config, Security Hub, Inspector, GuardDuty).
4. Use least-privilege, dedicated remediation paths where ordinary administrative access is intentionally blocked.
5. Distinguish genuine residual risk from tool-evaluation lag or service-managed resources.
6. Require explicit approval for architectural or conditional exceptions.
7. Re-run targeted regression checks after remediation rather than relying only on the original finding state.
8. Preserve failed command attempts as superseded evidence where they reflect CLI-shape errors rather than control failure.

2.2 Evidence standard

Evidence quality was graded by directness. Runtime AWS state and negative authorization tests were treated as stronger evidence than a console visual or a stale posture-management finding. Security Hub and AWS Config were used as independent compliance signals, but a stale finding was not allowed to overrule later direct-service proof without timestamp analysis.

3. A7 Control Objectives and Acceptance Criteria

Guardrail	Objective	Acceptance criterion	Final
GR-01	Prevent organization departure	NonProd cannot leave organization	PASS
GR-02	Protect core security services	Disabling CloudTrail/Config/GuardDuty/Security Hub denied outside approved roles	PASS
GR-03	Restrict regional activity	Workload creation limited to	PASS + Exception

Guardrail	Objective	Acceptance criterion	Final
		HK + approved SG recovery; Sydney governance-only	
GR-04	Prevent public exposure	S3/RDS/admin ingress exposure blocked or detected	PASS
GR-05	Enforce encryption	EBS default encryption on; unencrypted RDS/EBS paths denied	PASS
GR-06	Protect logs and backups	Workload administrators cannot weaken backup/log controls	PASS
GR-07	Enforce tagging governance	Core tags detected; remediable drift closed; managed resources documented	PASS + Exception

3.1 Required tagging standard

Tag	Requirement	Purpose
Owner	Required	Accountability / service ownership
Environment	Required	Lifecycle boundary: nonprod / prod
System	Required	Application / platform attribution
DataClassification	Required	Security and privacy handling
CostCenter	Required	Cost attribution
BackupPolicy	Required	Recovery intent
ManagedBy	Required	IaC / manual / exception ownership
RetentionClass	Standardized, not universally mandatory	Lifecycle / retention classification

4. A7 Event-by-Event Assessment

Event	Focus	Assessment outcome	Status
A7.1	Baseline governance and configuration inventory	Established current account, region, governance, tagging, public-access, encryption, and security-service state.	COMPLETE
A7.2	AWS Config implementation / recorder validation	Confirmed Config baseline and detective coverage; later identified regional prerequisites and rule gaps.	COMPLETE

Event	Focus	Assessment outcome	Status
A7.3	Rules and noncompliance analysis	Mapped Config / Security Hub control failures to actionable findings and architectural observations.	COMPLETE
A7.4	Control Tower governance and drift	Resolved F06/F07, implemented and validated GR-03, and proved log governance / CMK / audit-read path.	COMPLETE
A7.5	Security Hub CSPM	Centralized posture management, remediated F17-F21, distinguished real failures from stale Security Hub evaluations.	COMPLETE
A7.6	Tagging compliance	Closed HK drift, deployed SG tag rules, remediated unmanaged defaults, approved exception for 7 Control Tower managed resources.	COMPLETE
A7.7	Remediation validation	Final regression of GR-03-07, F09, F19, F20, F21; no unexpected drift.	COMPLETE
A7.8	Final Config & Compliance Assessment	This report consolidates control status, findings, exceptions, residual risk, and readiness.	FINAL

5. Detailed Guardrail Validation

5.1 GR-03 - Regional restriction and Sydney governance boundary

GR-03 became one of the most important controls in A7 because the Control Tower home region was Sydney even though the approved workload architecture was Hong Kong with Singapore recovery. The project did not attempt to erase that fact. Instead, it converted the mismatch into an explicit governance boundary: Sydney remains available for Control Tower and security-governance activities, while ordinary workload activity is denied.

Control component	Evidence / outcome
Control Tower Region Deny	Enabled for NonProd OU; allowed regions HK, SG, Sydney to preserve CT governance.
Custom SCP	clinic-gr03-sydney-governance-only-nonprod, policy p-3kbzgum.
Ordinary-admin negative test	HK/SG allowed where appropriate; Sydney and us-west-2 creation paths explicitly denied.

Control component	Evidence / outcome
Dedicated remediation role	Clinic-NonProd-Sydney-Security-Remediation-Role created for narrowly scoped security fixes.
SCP protection	Role itself protected against destructive IAM changes from ordinary administrators.
Applied-policy validation	Final Access Analyzer validation of applied SCP produced no findings.
Final status	GR-03 PASS / F19 CLOSED / residual LOW.

5.2 GR-04 - Public exposure prevention

GR-04 combined preventive account-level controls with detective posture checks. The final A7.7 regression confirmed Hong Kong VPC Block Public Access in block-ingress mode, zero BPA exclusions, S3 account public-access block, and zero security-group ingress rules open to 0.0.0.0/0 or ::/0 under the targeted check.

Validation	Final state
S3 account BPA	All four account-level block settings enabled.
VPC BPA	State update-complete; InternetGatewayBlockMode = block-ingress.
BPA exclusions	0
Public SG ingress	0 findings in final targeted regression
RDS public paths	Prevented by SCP / detective rules; no RDS workload present
Finding F15	CLOSED / REMEDIATED

5.3 GR-05 - Encryption enforcement

GR-05 moved beyond checking whether encryption happened to be enabled. It added preventive enforcement against disabling EBS encryption by default and against creating or restoring unencrypted RDS resources. Negative IAM simulation demonstrated explicit Organizations denial for prohibited paths and allowed results for compliant encrypted paths.

Validation	Final state
EBS encryption by default	true in Hong Kong
Disable EBS default encryption	explicitDeny by Organizations for normal administrators
Unencrypted RDS create/restore paths	explicitDeny
Encrypted RDS paths	allowed with rds:StorageEncrypted=true
Finding F16	CLOSED / REMEDIATED / LOW

5.4 GR-06 - Backup and log protection

GR-06 protects the recovery and audit controls from the same workload administrators whose mistakes or compromise could otherwise remove evidence or recovery points. The project implemented a dedicated backup-plan change role and protected the plan, source vault, log group, and privileged path.

Control	Final evidence
Source vault	clinic-fsx-nonprod-vault
Vault Lock	Locked=true; MinRetentionDays=14; MaxRetentionDays=30
Recovery points	27 at final E107 regression
Backup plan	clinic-fsx-12h-nonprod, 05:00/17:00 SGT schedule
FSx log group	/aws/fsx/windows, 1096-day retention, deletion protection validated earlier
Dedicated plan-change role	Clinic-NonProd-Backup-Plan-Change-Role
Normal admin	explicitDeny on protected backup mutations
Finding F14	CLOSED / REMEDIATED

5.5 GR-07 - Tagging governance

GR-07 used an Organizations Tag Policy plus two AWS Config REQUIRED_TAGS rules. Two rules were necessary because the managed rule supports six keys per rule; the first checks the six core keys and the second checks ManagedBy. RetentionClass remains standardized but is not universally required.

Hong Kong ended with zero noncompliant evaluations after remediation of the AWS-created Directory Service controller security group and companion directory tagging. Singapore initially exposed 10 unique network resources (20 rule failures) after the detective rules were extended there. Three unmanaged defaults were safely remediated. Seven Control Tower StackSet-owned resources were deliberately not direct-tagged because the stack was IN_SYNC with zero drift and its template does not declare the clinic tag schema. Security approved that exception on 13 Sep 2026.

6. Security Hub CSPM and Regional Drift Investigation

A7.5 provided the most operationally realistic part of the compliance assessment. Central Security Hub CSPM was validated from the delegated Security account, and a final targeted investigation focused on High and Critical findings in the NonProduction account.

6.1 Central posture-management architecture

Component	State
Delegated Security Hub administrator	REDACTED - Security account
Home / aggregation region	ap-southeast-2
Linked regions	ap-east-1 and ap-southeast-1
Configuration policy	b05bca26-0ae2-4092-ae7-ca285c5804fd

Component	State
Standard	AWS Foundational Security Best Practices v1.0.0
Service enabled	Yes
Disabled controls	None in central policy

6.2 Findings discovered and remediated

Finding	Issue	Disposition	Residual
F17	Security Hub regional linking / membership gap	CLOSED / REMEDIATED	LOW
F18	Config prerequisite gap for Security Hub in management regions	CLOSED / REMEDIATED	LOW
F19	Sydney security remediation path blocked for ordinary admins	CLOSED / REMEDIATED	LOW
F20	GuardDuty Singapore coverage drift	CLOSED / REMEDIATED	LOW
F21	Inspector Singapore scanning drift	CLOSED / REMEDIATED	LOW

6.3 Security Hub evaluation lag analysis

E92 and E94 showed an important distinction between control state and posture-engine evaluation state. Seven active Security Hub failures remained after direct remediation, but each retained an UpdatedAt timestamp that predated the later remediation evidence. EC2.2 and EC2.182 disappeared from the active-failed set after subsequent evaluation, confirming that Security Hub was converging asynchronously rather than detecting a new control rollback.

Control	Direct state	Security Hub E94	Assessment
SSM.7 Sydney	Remediated	FAILED / stale timestamp	Evaluation lag
SSM.7 Singapore	Remediated	FAILED / stale timestamp	Evaluation lag
GuardDuty.1 Singapore	Detector enabled	FAILED / old timestamp	Evaluation lag
Inspector.1	EC2 scanning enabled	FAILED / old timestamp	Evaluation lag
Inspector.2	ECR scanning enabled	FAILED / old timestamp	Evaluation lag
Inspector.3	Lambda Code scanning enabled	FAILED / old timestamp	Evaluation lag
Inspector.4	Lambda standard scanning	FAILED / old timestamp	Evaluation lag

Control	Direct state	Security Hub E94	Assessment
	enabled		

This was recorded as an informational observation rather than seven reopened findings. Repeating already-proven remediation solely to force an immediately green dashboard would have reduced evidence quality and increased change risk.

7. Tagging Compliance and Managed-Resource Exception

A7.6 illustrates why compliance engineering must account for infrastructure ownership. The initial Singapore result appeared to show a large remediation workload: 20 Config failures. Investigation reduced this to 10 unique resources in a single Control Tower-created VPC family.

Resource category	Count	Treatment
Control Tower StackSet VPC	1	Approved managed-resource exception
Control Tower private subnets	3	Approved managed-resource exception
Control Tower private route tables	3	Approved managed-resource exception
Implicit main route table	1	Directly tagged
Default network ACL	1	Directly tagged
Default security group	1	Directly tagged

The decisive evidence was CloudFormation drift detection: the Control Tower Account Factory stack was IN_SYNC with DriftedStackResourceCount=0 before remediation. The template itself declared only Control Tower Name / Network tags for the managed VPC, subnet, and route-table resources. Directly adding the clinic tag schema would have intentionally created stack drift. Security therefore approved F22 as an architectural exception with LOW residual risk on 13 Sep 2026.

8. A7.7 Remediation Validation

A7.7 was designed as a targeted regression, not a repetition of every A7 command. It sampled the controls most likely to drift again: regional restriction, public exposure, encryption, backup protection, tagging, GuardDuty, Inspector, Macie exception conditions, and the Sydney remediation role.

Area	Final regression result	Disposition
GR-03	Applied SCP and OU attachment intact; dedicated Sydney role present	PASS
GR-04	S3 BPA, HK VPC BPA, zero exclusions, zero public SG ingress	PASS
GR-05	EBS encryption by default = true	PASS
GR-06	Vault Lock retained; 14-30 day bounds; recovery points present	PASS
GR-07 HK	0 remaining noncompliant evaluations	PASS

Area	Final regression result	Disposition
GR-07 SG	Exactly 7 approved CT-managed residual resources; 0 unexpected	PASS + Exception
F09 Macie	0 NonProd S3 buckets; activation trigger not reached	PASS + Conditional Exception
F19 role	Role exists; 0 managed policies; expected inline policy	PASS
F20 GuardDuty	Exactly 1 SG detector; Status=ENABLED	PASS
F21 Inspector	Account + EC2/ECR/Lambda/LambdaCode ENABLED; failedAccounts=[]	PASS

9. Findings Register and Closure Position

ID	Finding	Final disposition	Residual
F01	Tagging gaps	Remediated	LOW
F02	EBS default encryption disabled	Remediated	LOW
F03	EBS snapshot public sharing control	Remediated	LOW
F04	SSM document public sharing	Remediated	LOW
F05	Hong Kong IAM recording gap	Remediated	LOW
F06	Control Tower home region mismatch	Approved architectural exception	LOW
F07	Control Tower logging / KMS governance	Remediated	LOW
F08	VPC Block Public Access	Remediated	LOW
F09	Macie not enabled	Approved conditional exception	LOW
F10	SSM automation logging	Remediated	LOW
F14	Workload-admin protection of logs/backups	Remediated	LOW
F15	Preventive public exposure control gap	Remediated	LOW
F16	Preventive encryption enforcement gap	Remediated	LOW
F17	Security Hub regional linking gap	Remediated	LOW

ID	Finding	Final disposition	Residual
F18	Security Hub / Config prerequisite gap	Remediated	LOW
F19	Sydney remediation path	Remediated	LOW
F20	GuardDuty Singapore drift	Remediated	LOW
F21	Inspector Singapore drift	Remediated	LOW
F22	GR-07 vs CT StackSet ownership conflict	Approved architectural exception	LOW

9.1 Notable observations not treated as open failures

- Security Hub post-remediation evaluation lag: seven stale ACTIVE/FAILED records remained temporarily after direct remediation proof; classified as informational observation.
- Management-account administrative work executed under IAM user Nexushua was identified as a separate governance observation because it conflicts with the approved federated / time-bound role baseline; it was intentionally not merged into F06 or F07.
- RoleLastUsed metadata for the Sydney remediation role reports ap-southeast-1. This is retained as an observation only because actual permissions and GR-03 enforcement are Sydney-scoped / exact-resource scoped.
- CFN / Control Tower StackSet service-role and termination-protection characteristics remain managed-service considerations rather than workload findings.
- FSx Single-AZ remains an accepted NonProduction architecture characteristic and is not treated as an A7 compliance failure.

10. Exception Register and Residual Risk

Exception	Scope	Rationale	Approval	Residual	Review trigger
EX-A7-01 / F06	Control Tower home in Sydney instead of originally approved workload / recovery model	Control Tower rebuild would introduce material governance risk and cost; Sydney restricted to governance use	Steve Tarvolds, Security Manager - 2026-09-11	LOW	Review on landing-zone rebuild / major architecture change
EX-A7-02 / F09	Macie disabled while NonProd owns no S3 buckets	No current S3 data set exists to inventory/classify; activate Macie before first sensitive S3 workload	Security Department - 2026-09-13	LOW	Trigger on any new S3 bucket containing clinic / PHI / PII / confidential data
EX-A7-03 / F22	Seven Singapore Control Tower StackSet resources do not carry clinic GR-07 tag schema	Direct tagging would intentionally create CloudFormation drift in an IN_SYNC CT-managed stack	Security Department - 2026-09-13	LOW	Review if Control Tower template becomes extensible or resources leave CT ownership
EX-A7-04	Sydney duplicate REQUIRED_TAGS rules not deployed under ordinary admin	GR-03 governance-only boundary intentionally blocks regional creation / modification; no clinic	Security governance decision	LOW	Review only if Sydney becomes approved workload or recovery region

Exception	Scope	Rationale	Approval	Residual	Review trigger
		workload is approved in Sydney			

10.1 Residual-risk assessment

Residual risk is assessed as LOW because the remaining deviations do not expose an unmitigated production workload path. Each residual is constrained by one or more compensating controls: Organizations SCPs, Control Tower ownership, OU-level policy, zero-workload conditions, centralized logging, Security Hub aggregation, or explicit activation triggers.

11. Evidence Quality, Limitations and Auditability

The evidence set is unusually strong for a portfolio environment because it contains direct AWS API outputs, negative authorization tests, cross-account role validation, remediation before/after state, CloudFormation drift detection, Security Hub timestamps, Config evaluations, and explicit exception approval decisions.

Evidence quality factor	Assessment
Directness	High - majority of conclusions backed by AWS API state or runtime authorization result.
Repeatability	High - evidence filenames preserve exact event/step sequence and commands can be rerun.
Separation of observation vs finding	Strong - stale posture records and CLI errors were not misclassified as control failures.
Exception governance	Strong - material deviations were not silently accepted; approval and triggers were recorded.
Regional coverage	HK and SG workload/recovery paths validated; Sydney constrained by approved governance-only boundary.
Known limitation	This is a controlled NonProduction estate, not a long-running multi-team production environment.

11.1 Superseded command evidence

Several A7.7 CLI attempts used incorrect AWS CLI subcommands or invalid API filters. These were treated as command-shape errors and superseded by corrected evidence. They are not control failures. Examples include the VPC BPA read command, local filtering of security-group rule direction, Backup Vault Lock read path, and the requirement to pass MaxResults when listing BPA exclusions.

12. Final Compliance Verdict and A8 Readiness

A7 is complete. The NonProduction environment has a defensible configuration-governance posture suitable for proceeding to A8 readiness assessment. The environment is not claimed to be perfect or production-certified. Instead, the report demonstrates that known deviations are either remediated, constrained by stronger controls, or explicitly approved with LOW residual risk and future review triggers.

Decision area	Verdict
A7 completion	PASS + APPROVED EXCEPTIONS / CLOSED
Unresolved Critical findings	0
Unresolved High findings	0 within A7 scope
Open remediation actions	0 material actions
Approved LOW exceptions	Documented and review-triggered
Ready to proceed to A8	YES
Recommended A8 emphasis	Readiness gates, operational runbooks, restore / DR validation, cutover control, final evidence packaging

Final sign-off statement: Mission 2 Event A7 demonstrates that the clinic NonProduction AWS environment is governed by validated preventive and detective controls, that identified configuration and security drift has been remediated or formally accepted, and that residual risk is sufficiently controlled to proceed to A8 readiness assessment.

Appendix A - Evidence Register

The register below lists the principal evidence families used in the final assessment. Individual sub-evidence files within each family preserve the exact before/after or regional state.

Evidence family	Purpose
E53-E57	GR-04 / GR-05 baseline, public exposure and encryption enforcement
E63	GR-06 dedicated backup-plan change role and negative tests
E73	GR-03 regional authorization matrix
E79-E80	Control Tower logging/KMS remediation and live audit-read proof
E81-E86	Security Hub delegated administration, policy, linking and Config prerequisites
E87	Initial High/Critical Security Hub baseline
E89	Sydney dedicated remediation path and EC2 control remediation
E90	GuardDuty Singapore delegated-admin and member remediation
E91	Inspector Singapore delegated-admin, membership and scanning remediation
E92	Targeted Security Hub regression identifying SG EC2 residuals and stale findings
E93	Singapore EC2.182 / EC2.2 direct remediation

Evidence family	Purpose
E94	Final targeted Security Hub ACTIVE/FAILED regression
E95-E97	A7.6 Tag Policy, Config rule coverage and current noncompliance discovery
E98-E99	Hong Kong Directory Service / controller SG tag remediation
E100-E101	Singapore REQUIRED_TAGS rule deployment and noncompliance discovery
E102-E104	Singapore network-family analysis, CT drift preflight, safe remediation
E105-E106	F19 applied-policy validation and F09 Macie / S3 disposition
E107	Final multi-control remediation regression and A7.7 closure

Appendix B - Key Resource and Control Inventory

Asset / control	Identifier
NonProd account	REDACTED
Management account	REDACTED
Security account	REDACTED
Log Archive	REDACTED
Control Tower landing zone	REDACTED 290K3TFWCGX5WSTM
GR-03 custom SCP	p-3kbzguam - clinic-gr03-sydney-governance-only-nonprod
GR-05 SCP	p-f5hvdzk2 - clinic-gr05-enforce-encryption-nonprod
GR-06 SCP	p-edaqss1t - clinic-gr06-protect-logs-backups-nonprod
Sydney remediation role	REDACTED Remediation-Role
Backup plan	59a8bde5-79f0-4d6d-b849-ff44aab94d32 - clinic-fsx-12h-nonprod
Source backup vault	clinic-fsx-nonprod-vault
FSx current resource	REDACTED
Security Hub aggregator	REDACTED aggregator/08d03ac5-a0d2-d22a-723b-b12144443e20
Security Hub configuration policy	b05bca26-0ae2-4092-ae7-ca285c5804fd
GuardDuty SG detector	6ad04b30b3a5afb6e8c0a595292e79b5

Asset / control	Identifier
SG CT VPC	REDACTED
SG default SG	REDACTED
HK AD controller SG	REDACTED
HK Managed Microsoft AD	REDACTED

Appendix C - Engineering Lessons and Portfolio Value

- Compliance dashboards are not authoritative in isolation. Direct service state plus timestamps are necessary to distinguish genuine failure from evaluation lag.
- Preventive controls can block legitimate remediation. The correct response is a dedicated least-privilege remediation path, not weakening the preventive control globally.
- Infrastructure ownership matters. For Control Tower / StackSet resources, forcing a custom tagging policy can create IaC drift and reduce governance quality.
- Regional cloud-security services require explicit regional reasoning. GuardDuty, Inspector, Security Hub, Config and Macie can each expose different forms of regional drift.
- Exception handling is part of security engineering. A LOW-risk exception with scope, rationale, compensating controls, approval and review trigger is stronger than an undocumented workaround.
- Negative tests are high-value evidence. Demonstrating that a prohibited action returns Organizations=false / explicitDeny is stronger than merely stating that an SCP exists.
- Backup controls must protect both data and governance. Vault Lock, retention bounds, dedicated change roles and cross-account copy evidence form a stronger recovery posture than a simple scheduled backup.
- Operational mistakes can become portfolio evidence when they are investigated and controlled. The accidental FSx deletion was preserved as a misconfiguration / recovery scenario rather than hidden.

END OF A7.8 FINAL CONFIG & COMPLIANCE ASSESSMENT

Appendix D - Detailed Finding Narratives

Purpose. This appendix expands the closure basis for each material A7 finding. It is intentionally verbose so that the final report preserves why a finding existed, what engineering decision was made, what evidence supported closure, and what residual risk remains.

F01 - Tagging gaps

Aspect	Assessment
Issue / trigger	Baseline discovery identified resources that did not meet the clinic governance tagging standard.
Security / governance significance	Missing ownership, environment, classification, cost, backup, and management metadata weakens operational accountability and compliance reporting.
Treatment and closure basis	Remediation applied the agreed tag schema and later A7.6 revalidated the regional tagging model. The Hong Kong Directory Service controller SG was subsequently found to fail both REQUIRED_TAGS rules and was remediated with its parent directory tagged for consistency.
Primary evidence	E95-E99; GR-07 Config evaluations
Final disposition	CLOSED / REMEDIATED / LOW

F02 - EBS default encryption

Aspect	Assessment
Issue / trigger	EBS default encryption was not aligned with the intended encryption baseline.
Security / governance significance	New block storage could be created without encryption if callers omitted an encryption flag.
Treatment and closure basis	EBS encryption by default was enabled and GR-05 later added preventive SCP enforcement so ordinary administrators cannot disable the setting. E107f reconfirmed EbsEncryptionByDefault=true.
Primary evidence	GR-05 E57 series; E107f
Final disposition	CLOSED / REMEDIATED / LOW

F03 - EBS snapshot public sharing

Aspect	Assessment
Issue / trigger	Regional snapshot public-sharing protection required hardening and later regional revalidation.
Security / governance significance	Publicly shareable snapshots create a direct confidentiality risk for workload data.
Treatment and closure basis	Public snapshot sharing controls were enabled and later

	Singapore/Sydney regional checks were incorporated into the broader posture remediation work. Singapore EC2.182 was explicitly remediated in E93.
Primary evidence	A7 baseline; E89d; E93a-c; E92/E94
Final disposition	CLOSED / REMEDIATED / LOW

F04 - SSM document public sharing

Aspect	Assessment
Issue / trigger	Systems Manager public sharing was not consistently blocked across all governed regions.
Security / governance significance	Publicly shared SSM documents can expose automation content or create an uncontrolled distribution path.
Treatment and closure basis	The block-public-sharing setting was remediated. Security Hub retained stale SSM.7 findings with timestamps predating remediation, so the final position relied on direct state and timestamp analysis rather than repeating the change.
Primary evidence	A7 baseline; E89cR11 corrected path; E92; E94
Final disposition	CLOSED / REMEDIATED / LOW

F05 - Hong Kong IAM recording

Aspect	Assessment
Issue / trigger	AWS Config recording coverage for IAM-related configuration items in Hong Kong was incomplete.
Security / governance significance	Incomplete configuration history reduces auditability and weakens compliance rule evaluation.
Treatment and closure basis	Recorder configuration was corrected and later Security Hub / Config prerequisite work reinforced regional configuration coverage.
Primary evidence	A7.2/A7.3 evidence; F18 remediation evidence
Final disposition	CLOSED / REMEDIATED / LOW

F06 - Control Tower home-region mismatch

Aspect	Assessment
Issue / trigger	The actual Control Tower landing zone is homed in Sydney although the intended workload/recovery architecture is Hong Kong/Singapore.
Security / governance significance	A regional mismatch can create governance confusion, duplicated control surfaces, and pressure to weaken region restrictions.
Treatment and closure basis	The mismatch was treated as an architectural exception rather than

	hidden. Sydney was constrained to governance-only activity under GR-03, while Hong Kong remained workload-primary and Singapore recovery. Security Manager approval was recorded on 11 Sep 2026.
Primary evidence	Control Tower landing-zone evidence; E73; approval record
Final disposition	CLOSED / APPROVED ARCHITECTURAL EXCEPTION / LOW

F07 - Control Tower logging and KMS governance

Aspect	Assessment
Issue / trigger	Central Control Tower logging required a dedicated, validated encryption and audit-read path.
Security / governance significance	Weak or inaccessible log encryption / read paths can undermine incident response and audit evidence.
Treatment and closure basis	The organization trail was confirmed multi-region with log-file validation, encrypted by dedicated CMK c177e3b1-d1d9-4783-8537-c9b1fbc4a754. The final E80 validation proved fresh log delivery and successful read/decompression through the intended audit analyst role.
Primary evidence	E79-E80
Final disposition	CLOSED / REMEDIATED / LOW

F08 - VPC Block Public Access

Aspect	Assessment
Issue / trigger	The VPC BPA posture did not initially satisfy the intended preventive internet-exposure baseline.
Security / governance significance	Uncontrolled internet gateway access can create accidental exposure paths.
Treatment and closure basis	VPC BPA was enabled in block-ingress mode. E107d reconfirmed update-complete/block-ingress and E107d2 proved zero active exclusions.
Primary evidence	A7 baseline; E107d/d2
Final disposition	CLOSED / REMEDIATED / LOW

F09 - Macie disabled

Aspect	Assessment
Issue / trigger	Macie is not enabled in NonProduction.
Security / governance significance	If sensitive data were placed in S3 without Macie, automated sensitive-data discovery would be absent.
Treatment and closure basis	E106/E107o proved that NonProduction owns zero S3 buckets. Security approved a conditional exception on 13 Sep 2026: Macie

	must be assessed and enabled in the relevant workload region before the first S3 workload containing clinic, PHI, PII, confidential, or otherwise classified data is introduced.
Primary evidence	E106a-c; E107o; security approval 2026-09-13
Final disposition	CLOSED / APPROVED CONDITIONAL EXCEPTION / LOW

F10 - SSM automation logging

Aspect	Assessment
Issue / trigger	SSM automation logging / evidence capture required alignment with the operations baseline.
Security / governance significance	Insufficient automation logging can make privileged changes difficult to reconstruct.
Treatment and closure basis	Logging was remediated and retained as part of the broader evidence-preservation posture.
Primary evidence	A7 remediation evidence
Final disposition	CLOSED / REMEDIATED / LOW

F14 - Workload-admin protection of logs and backups

Aspect	Assessment
Issue / trigger	Normal workload administrators had too much ability to weaken backup/log governance.
Security / governance significance	A compromised or mistaken workload admin could otherwise remove recovery or audit evidence.
Treatment and closure basis	GR-06 introduced SCP protection for backup plans and logging plus a dedicated cross-account backup-plan change role with narrow permissions. Runtime simulation proved the dedicated role allowed while ordinary admin paths were explicitly denied.
Primary evidence	E63 series; E107g-i
Final disposition	CLOSED / REMEDIATED / LOW

F15 - Preventive public exposure control gap

Aspect	Assessment
Issue / trigger	Detective public-access controls existed, but administrators could still modify public-access protections or create public RDS paths.
Security / governance significance	A detective-only posture allows a window in which exposure can exist before detection.
Treatment and closure basis	GR-04 SCP enforcement was added to protect S3/VPC BPA configuration and deny public RDS create/restore paths while

	preserving compliant private paths.
Primary evidence	E53-E54 baseline; GR-04 SCP tests
Final disposition	CLOSED / REMEDIATED / LOW

F16 - Preventive encryption enforcement gap

Aspect	Assessment
Issue / trigger	Encryption settings could be weakened or unencrypted RDS provisioning attempted.
Security / governance significance	Configuration drift could create plaintext storage despite an otherwise encrypted architecture.
Treatment and closure basis	GR-05 SCP p-f5hvdzk2 denies disabling EBS default encryption and unencrypted RDS create/restore operations. Compliant encrypted paths remain allowed.
Primary evidence	E57g-k; E107f
Final disposition	CLOSED / REMEDIATED / LOW

F17 - Security Hub regional linking / membership

Aspect	Assessment
Issue / trigger	Singapore was not fully linked into the centralized Security Hub posture model.
Security / governance significance	Regional findings could be absent from the delegated-administrator view.
Treatment and closure basis	Singapore member/linking was corrected and the central aggregation topology revalidated. Approval for the remediation was recorded during A7.5.
Primary evidence	E81-E86
Final disposition	CLOSED / REMEDIATED / LOW

F18 - Security Hub Config prerequisite gap

Aspect	Assessment
Issue / trigger	Required Config prerequisites were missing in management-region coverage used by Security Hub.
Security / governance significance	Security Hub controls that depend on Config cannot evaluate correctly without recorder coverage.
Treatment and closure basis	Config prerequisite coverage was implemented in Hong Kong and Singapore, with Sydney retaining its existing recorder. Final association state succeeded.
Primary evidence	E86 series

Final disposition	CLOSED / REMEDIATED / LOW

F19 - Sydney security remediation path

Aspect	Assessment
Issue / trigger	GR-03 correctly blocked ordinary NonProduction administrators from performing remediation in Sydney.
Security / governance significance	Without a controlled exception path, genuine governance-region security findings could not be corrected without weakening the regional deny policy.
Treatment and closure basis	A dedicated Clinic-NonProd-Sydney-Security-Remediation-Role was created with exact Security-account trust and narrow Sydney SSM/EBS/EC2 permissions. The applied GR-03 policy was revalidated successfully in E105, and E107p-r confirmed role integrity and zero attached managed policies.
Primary evidence	E89c; E105a-g; E107p-r
Final disposition	CLOSED / REMEDIATED / LOW

F20 - GuardDuty Singapore coverage drift

Aspect	Assessment
Issue / trigger	The NonProduction account had no active GuardDuty detector/member relationship in Singapore.
Security / governance significance	Threat detection coverage was absent in an approved recovery region.
Treatment and closure basis	The Security account was enabled as regional administrator, NonProduction was associated as a member, and one NonProduction Singapore detector was created. E107l-m reconfirmed exactly one detector with Status=ENABLED.
Primary evidence	E90; E107l-m
Final disposition	CLOSED / REMEDIATED / LOW

F21 - Inspector Singapore scanning drift

Aspect	Assessment
Issue / trigger	Inspector scanning was disabled for NonProduction in Singapore.
Security / governance significance	Vulnerability and code-scanning coverage was absent in an approved recovery region.
Treatment and closure basis	The Security account was enabled as regional delegated administrator, NonProduction was associated, and EC2/ECR/Lambda/Lambda Code scanning reached ENABLED. E107n

	reconfirmed the state with failedAccounts=[].
Primary evidence	E91; E107n
Final disposition	CLOSED / REMEDIATED / LOW

F22 - GR-07 versus Control Tower StackSet ownership

Aspect	Assessment
Issue / trigger	Seven Singapore Control Tower Account Factory resources fail the clinic REQUIRED_TAGS rules.
Security / governance significance	Directly forcing the clinic tags would satisfy Config but intentionally diverge from the Control Tower-managed CloudFormation baseline.
Treatment and closure basis	E103 proved the stack IN_SYNC with zero drift and the template defines only native Name/Network tags for these resources. Three unmanaged default resources were separately remediated in E104. Security approved the seven-resource managed exception on 13 Sep 2026.
Primary evidence	E102-E104; security approval 2026-09-13
Final disposition	CLOSED / APPROVED ARCHITECTURAL EXCEPTION / LOW

Detailed finding appendix complete - all material A7 findings have a documented closure basis.